

BTS SIO 2026

☐ Administration des systèmes et des réseaux (E6 – SISR)

☒ Conception et développement d'applications (E6 – SLAM)

PAGE DE PRÉSENTATION DU DOSSIER

N° d'inscription¹ : | 0 | 2 | 2 | 4 | 8 | 1 | 0 | 9 | 8 | 4 | 8 |

NOM : SANJIVY

PRÉNOM : Romain

Date de passage² : / / 2026

Heure de passage² :h.....

CATÉGORIE CANDIDAT¹ (UNE CASE À COCHER)

☐ Scolaire

☒ Apprenti

☐ Formation professionnelle continue

☐ Expérience professionnelle

☐ Ex-scolaire

☐ Ex-apprenti

☐ Ex-formation professionnelle continue

¹ Informations communiquées sur votre confirmation d'inscription

² Informations à ne pas compléter

Tampon de L'établissement

ANNEXE VII-1-B : Fiche descriptive de réalisation professionnelle (recto)

Épreuve E6 - Conception et développement d'applications (option SLAM)

DESCRIPTION D'UNE RÉALISATION PROFESSIONNELLE		N° réalisation : 1
Nom, prénom : Sanjivy Romain		N° candidat : 2248109848
Épreuve ponctuelle ☒	Contrôle en cours de formation ☐	Date : 01 / 04 / 2026
Organisation support de la réalisation professionnelle Le Muscle Sympa — Site web complet pour une salle de sport fictive		
Intitulé de la réalisation professionnelle Le Muscle Sympa — gestion des membres, abonnements, programmes sportifs personnalisés et espace client		
Période de réalisation : 2024 – 2026 Lieu : Lycée Louis Bascan Modalité : ☒ Seul(e) ☐ En équipe		
Compétences travaillées ☒ Concevoir et développer une solution applicative ☒ Assurer la maintenance corrective ou évolutive d'une solution applicative ☒ Gérer les données		
Conditions de réalisation (ressources fournies, résultats attendus) Ressources fournies : Poste de développement personnel, serveur local XAMPP, base de données MySQL vierge, Visual Studio Code. Résultats attendus : • Système d'inscription et de connexion sécurisé avec gestion de sessions • Présentation et souscription aux abonnements (4 formules) avec simulation de paiement • Réinitialisation de mot de passe par email avec token sécurisé • Questionnaire permettant de commander un programme sportif personnalisé (4 types) • Génération automatique du programme et stockage en base de données • Espace client avec consultation et téléchargement des programmes achetés • Sécurisation complète : injections SQL, brute force, spam, XSS		
Description des ressources documentaires, matérielles et logicielles utiliséesⁱ Matérielles : Poste de développement Windows 11, serveur local XAMPP (Apache 2.4, MySQL 8 / MariaDB) Logicielles : • Langages : PHP 8, SQL, HTML5, CSS3, JavaScript Vanilla • SGBD : MySQL / MariaDB — administration via phpMyAdmin • Serveur web : Apache (XAMPP) • IDE : Visual Studio Code • Versioning : Git, GitHub (github.com/Romain-SNVY78/Le_Muscle_Sympa) • Bibliothèque email : PHPMailer (intégration manuelle, sans Composer) • Service SMTP : SendGrid (envoi des emails de réinitialisation de mot de passe)		
Documentaires : Documentation officielle PHP (php.net), MDN Web Docs, référentiel BTS SIO		
Modalités d'accès aux productions et à leur documentation • Dépôt GitHub : https://github.com/Romain-SNVY78/Le_Muscle_Sympa • Accès en ligne : https://lms.testoxylog.fr • Compte de test : ID : jurys.test@gmail.com MDP : Azerty123 • Un fichier README.md est présent à la racine de mon projet pour vous aider à son installation		

**ANNEXE VII-1-B : Fiche descriptive de réalisation professionnelle
(verso, éventuellement pages suivantes)**

Épreuve E6 - Conception et développement d'applications (option SLAM)

Descriptif de la réalisation professionnelle, y compris les productions réalisées et schémas explicatifs

Contexte

"Le Muscle Sympa" est un site web complet pour une salle de sport. Le projet couvre l'ensemble du parcours utilisateur : arrivée sur le site, création de compte, souscription à un abonnement, commande d'un programme sportif personnalisé et consultation de l'espace client.

Le projet a été développé de manière évolutive : une première phase a couvert l'authentification et les abonnements, une seconde phase (maintenance évolutive) a ajouté le module de programmes sportifs personnalisés.

Architecture du projet

Architecture MVC simplifiée sans framework :

- [app](#) — logique métier : config.php, [db.php](#) (connexion PDO), [helpers.php](#) (fonctions utilitaires)
- [public](#) — pages PHP accessibles, assets CSS/JS/images
- [api](#) — endpoints back-end sécurisés
- [partials](#) — composants réutilisables (header, footer)
- [phpmailer](#) — bibliothèque PHPMailer intégrée manuellement
- [migrations](#) — scripts SQL de création des tables

Base de données

Table users :

#	Nom	Type	Interclassement	Attributs	Null	Valeur par défaut	Commentaires	Extra	Action
☐ 1	id	int(10)		UNSIGNED	Non	Aucun(e)		AUTO_INCREMENT	Modifier Supprimer Plus
☐ 2	first_name	varchar(100)	utf8mb4_general_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 3	last_name	varchar(100)	utf8mb4_general_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 4	email	varchar(190)	utf8mb4_general_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 5	phone	varchar(30)	utf8mb4_general_ci		Oui	NULL			Modifier Supprimer Plus
☐ 6	birthdate	date			Oui	NULL			Modifier Supprimer Plus
☐ 7	password_hash	varchar(255)	utf8mb4_general_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 8	created_at	datetime			Non	Aucun(e)			Modifier Supprimer Plus
☐ 9	plan	varchar(40)	utf8mb4_general_ci		Oui	NULL			Modifier Supprimer Plus

Table password_resets :

#	Nom	Type	Interclassement	Attributs	Null	Valeur par défaut	Commentaires	Extra	Action
☐ 1	id	int(10)		UNSIGNED	Non	Aucun(e)		AUTO_INCREMENT	Modifier Supprimer Plus
☐ 2	user_id	int(10)		UNSIGNED	Non	Aucun(e)			Modifier Supprimer Plus
☐ 3	selector	char(16)	utf8mb4_unicode_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 4	verifier_hash	char(64)	utf8mb4_unicode_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐ 5	expires_at	datetime			Non	Aucun(e)			Modifier Supprimer Plus
☐ 6	used	tinyint(1)			Non	0			Modifier Supprimer Plus
☐ 7	created_at	datetime			Non	current_timestamp()			Modifier Supprimer Plus

Table user_programs :

#	Nom	Type	Interclassement	Attributs	Null	Valeur par défaut	Commentaires	Extra	Action
☐	1 id	int(10)		UNSIGNED	Non	Aucun(e)		AUTO_INCREMENT	Modifier Supprimer Plus
☐	2 user_id	int(10)		UNSIGNED	Non	Aucun(e)			Modifier Supprimer Plus
☐	3 program_type	varchar(50)	utf8mb4_unicode_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐	4 program_name	varchar(255)	utf8mb4_unicode_ci		Non	Aucun(e)			Modifier Supprimer Plus
☐	5 first_name	varchar(100)	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	6 email	varchar(100)	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	7 age	int(11)			Oui	NULL			Modifier Supprimer Plus
☐	8 poids	decimal(5,1)			Oui	NULL			Modifier Supprimer Plus
☐	9 taille	int(11)			Oui	NULL			Modifier Supprimer Plus
☐	10 objectif	varchar(50)	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	11 experience	varchar(50)	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	12 frequence	int(11)			Oui	NULL			Modifier Supprimer Plus
☐	13 jours	varchar(255)	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	14 equip	varchar(100)	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	15 contraintes	text	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	16 duree	int(11)			Oui	NULL			Modifier Supprimer Plus
☐	17 preferences	text	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	18 program_content	longtext	utf8mb4_unicode_ci		Oui	NULL			Modifier Supprimer Plus
☐	19 purchased_at	timestamp			Non	current_timestamp()			Modifier Supprimer Plus
☐	20 price	decimal(10,2)			Oui	NULL			Modifier Supprimer Plus

Productions réalisées

1. Système d'inscription et de connexion ([auth.php](#))

Deux onglets sur la même page : inscription (validation email, longueur mot de passe, détection doublon en BDD, hachage password_hash()) et connexion (vérification password_verify(), création de session avec user_id, plan, first_name). Protection honeypot anti-bot et rate limiting (5 tentatives/minute en session).

Mon compte

Prénom

Nom

Email

Téléphone

Date de naissance

Mot de passe

Confirmer

Créer mon compte

J'ai déjà un compte

Données utilisées uniquement dans le cadre du projet BTS SIO.

2. Gestion des abonnements ([abonnements.php](#), [confirm_plan.php](#), [pay.php](#), [pay_result.php](#))

Présentation des 4 formules (SOLO 20€, SOLO+ 50€, DUO 30€, DUO+ 80€). Après sélection, confirmation du choix puis simulation de paiement (formulaire carte bancaire). À la validation, mise à jour du champ plan en BDD (UPDATE users SET plan = ? WHERE id = ?) et mise à jour de la session. Si l'utilisateur n'est pas connecté, redirection automatique vers la connexion avec mémorisation du choix (pending_plan en session).

SOLO

20€ / mois

✓ Accès à tous les équipements

✓ Ambiance motivante & conviviale

✓ Sans frais cachés

Choisir SOLO

Idéal pour démarrer sereinement.

SOLO +

50€ / mois

✓ Accès à tous les équipements

✓ 2h de coaching offertes / mois

✓ Suivi personnalisé

Choisir SOLO +

Le meilleur rapport progrès/prix.

DUO

30€ / mois

✓ Pour 2 personnes

✓ Accès à tous les équipements

✓ Venez ensemble, progressez ensemble

Choisir DUO

Parfait en couple ou entre amis.

DUO +

80€ / mois

✓ Pour 2 personnes

✓ Accès à tous les équipements

✓ 4h de coaching offertes / mois

Choisir DUO +

Coaching inclus pour progresser vite.

3. Réinitialisation de mot de passe ([forgot.php](#), [reset.php](#))

Génération d'un double token : selector (16 chars) + verifier (64 chars, hashé en SHA-256 en BDD). Lien valide 30 minutes. Envoi par email via PHPMailer + SendGrid SMTP. Validation à la réinitialisation : comparaison du hash, vérification de l'expiration, mise à jour du mot de passe et invalidation du token (used = 1). Protection : ne révèle jamais si un email existe ou non.

4. Questionnaire programmes sportifs ([questionnaire.php](#))

Formulaire adaptatif selon le type de programme choisi (renforcement musculaire, endurance, esthétique, entretien). Collecte : prénom, email, âge, poids, taille, objectif spécifique, niveau d'expérience, fréquence hebdomadaire, jours disponibles, équipement, contraintes physiques, durée de séance. Les données sont sérialisées en JSON via un champ caché et transmises à [pay.php](#), puis stockées en \$_SESSION['program_data'].

Questionnaire — Endurance (10 €)

Quelques questions pour personnaliser votre programme (10 €) — Endurance.

Prénom

Alex

Email

vous@example.com

Âge

24

Poids (kg)

72

Taille (cm)

178

Objectif spécifique

— Sélectionner —

Affine les plages de répétitions, l'intensité et le volume d'entraînement.

Expérience en musculation

— Sélectionner —

Séances / semaine souhaitées

— Sélectionner —

Le programme sera structuré en "Jour 1", "Jour 2", etc. pour plus de flexibilité.

Durée souhaitée par séance

— Sélectionner —

Équipements à disposition

— Sélectionner —

Les séances seront ajustées à votre temps disponible.

Blessures / contraintes

Épaule fragile, lombaires, etc.

Vos informations ne sont utilisées que pour générer votre proposition de programme personnalisé (projet – simulation).

5. Génération et enregistrement du programme ([pay_result.php](#))

Après le paiement simulé (10€), la fonction `generateProgram()` analyse les paramètres du questionnaire et génère un programme d'entraînement structuré en HTML. Le contenu est inséré dans la table `user_programs` avec toutes les métadonnées. L'abonnement est également mis à jour en BDD si l'achat porte sur un plan.

```
// Génération du contenu du programme (simulation)
$programContent = generateProgram($program, $programData);

// Enregistrement en BDD
$stmt = $pdo->prepare("
    INSERT INTO user_programs (
        user_id, program_type, program_name,
        first_name, email, age, poids, taille,
        objectif, experience, frequence, jours,
        equip, contraintes, duree, preferences,
        program_content, price
    ) VALUES (?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?)
");

// Enregistrement en BDD
$stmt = $pdo->prepare("
    INSERT INTO user_programs (
        user_id, program_type, program_name,
        first_name, email, age, poids, taille,
        objectif, experience, frequence, jours,
        equip, contraintes, duree, preferences,
        program_content, price
    ) VALUES (?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?, ?)
");
```

6. Espace client ([profile.php](#))

Page à deux onglets, accessible uniquement aux utilisateurs connectés (redirection sinon) : "Vue d'ensemble" (informations personnelles, abonnement actuel) et "Mes programmes" (liste des programmes achetés avec date et prix, boutons "Consulter" et "Télécharger").

7. API de consultation ([api/get-program.php](#))

Retourne le contenu HTML du programme demandé. Vérification que l'utilisateur connecté est bien propriétaire (WHERE id = ? AND user_id = ?). Retourne HTTP 403 si non connecté, HTTP 404 si programme introuvable.

```
<?php
session_start();

if (empty($_SESSION['user_id']) || empty($_GET['id'])) {
    http_response_code(403);
    echo 'Accès refusé';
    exit;
}

try {
    require_once __DIR__ . '/../../app/db.php';

    $stmt = $pdo->prepare("
        SELECT id, program_name, program_type, program_content, purchased_at
        FROM user_programs
        WHERE id = ? AND user_id = ?
    ");

    $stmt->execute([$_GET['id'], $_SESSION['user_id']]);
    $program = $stmt->fetch(PDO::FETCH_ASSOC);

    if (!$program) {
        http_response_code(404);
        echo 'Programme non trouvé';
        exit;
    }

    echo $program['program_content'];
} catch (Throwable $e) {
    http_response_code(500);
    echo 'Erreur serveur';
}
```

8. API de téléchargement ([api/download-program.php](#))

Génère un fichier HTML complet avec mise en forme et l'envoi en téléchargement via Content-Disposition: attachment. Mêmes contrôles de sécurité que l'API de consultation.

```

// Génération du fichier HTML
$html = '<!DOCTYPE html>'
<html lang="fr">
<head>
  <meta charset="UTF-8">
  <title>'<htmlspecialchars($program['program_name']).'</title>
  <style>
    body { font-family: Arial, sans-serif; margin: 20px; line-height: 1.6; }
    h1, h2, h3 { color: #ff8000; }
    .info { background: #f5f5f5; padding: 15px; border-radius: 8px; margin: 20px 0; }
  </style>
</head>
<body>
  <h1>'<htmlspecialchars($program['program_name']).'</h1>
  <div class="info">
    <p><strong>Acheté le:</strong> '.date('d/m/Y à H:i', strtotime($program['purchased_at'])).'</p>
  </div>
  ' . $program['program_content'] . '
  <hr>
  <p style="color: #999; font-size: 12px; margin-top: 30px;">
    Document généré le '.date('d/m/Y à H:i').' - Le Muscle Sympa
  </p>
</body>
</html>';

// Envoyer en téléchargement
header('Content-Type: text/html; charset=UTF-8');
header('Content-Disposition: attachment; filename="programme_'.date('Ymd_His').'.html"');
echo $html;

} catch (Throwable $e) {
  http_response_code(500);
  die('Erreur serveur');
}

```

Flux applicatif global

Page d'accueil → Abonnements → Connexion/Inscription → Paiement → Confirmation → Espace client
 → Programmes → Questionnaire ————— ↑ → Consultation
 → Téléchargement

Sécurité

- Requêtes 100% préparées (PDO) → protection injections SQL
- password_hash() / password_verify() (bcrypt) → stockage sécurisé
- Honeypot → rejet silencieux des bots
- Rate limiting par session → protection brute force
- Double token selector/verifier hashé → réinitialisation mot de passe sécurisée
- htmlspecialchars() systématique en sortie → protection XSS
- Contrôle propriétaire sur toutes les APIs → pas d'accès aux données d'autrui
